Incident response plan (security and service incidents)

Covers cyber-security incidents (CERT-In Directions, 28 April 2022), personal-data breaches (DPDP Act, once in force) and major service outages. Review every six months and after every incident.

1. Roles

Role	Who (fill in)	Responsibility
Incident lead	Engineering lead	Runs the response, makes technical decisions
CERT-In point of contact	Founder / designated officer	Registered with CERT-In; files reports
Communications	Founder	Customers, partners, B2B clients, regulators
Scribe	Anyone on call	Timeline of actions with timestamps

Keep an up-to-date contact sheet for hosting (Vercel, Render), database (Neon), email/SMS providers, Razorpay and counsel.

2. Severity

Level	Examples	Response
SEV-1	Data breach or suspected one; admin account compromise; booking or dispatch fully down; payment fraud	Immediate; all hands; consider CERT-In report
SEV-2	Partial outage (SMS OTP failing, maps failing); a single partner account compromised	Within 30 min
SEV-3	Degraded performance; non-sensitive bug	Next business day

3. Steps

1. **Detect and record:** note the time you first noticed it. The 6-hour CERT-In clock starts here.
2. **Contain:** revoke sessions (rotate `AUTH_SECRET` signs everyone out), disable compromised staff accounts (Admin → Users), rotate leaked keys (Razorpay, SMTP, MSG91, database), switch payments to "coming soon" if payment flow is affected.
3. **Preserve evidence:** export relevant logs (hosting, database, `AuditLog`, `NotificationLog`) before they roll over. Do not wipe affected systems.
4. **Assess:** what data and how many people are affected? Is it a CERT-In specified incident type, such as unauthorised access, data breach, data leak, or attack on servers or applications?
5. **Report:**
   - **CERT-In within 6 hours** of noticing a specified incident (incident@cert-in.org.in, using the CERT-In format).
   - **Data Protection Board and affected individuals** as required by the DPDP Rules once those provisions are in force.

    - B2B clients per contract; payment provider if card or UPI data may be involved.
6. **Recover:** restore service (Neon point-in-time restore if data integrity is affected), verify, and monitor.
7. **Review within 5 working days:** root cause, what worked, actions with owners and dates. Update this plan and the risk register.

4. Logs to keep (CERT-In: rolling 180 days)

Application logs (hosting), database logs, `AuditLog`, authentication events (`Session`, `OtpChallenge`), admin actions, webhook receipts. Configure a log drain from Vercel and Render to storage under our control. The CERT-In directions speak of Indian jurisdiction, so check the current CERT-In FAQ clarifications with counsel.

5. Service-outage playbook (non-security)

Failure	Immediate workaround
Website/app down	Publish the emergency phone number on social and Google Business Profile; desk takes bookings by phone and logs them in admin when back
SMS OTP failing	Customers can use email OTP (built-in fallback); check DLT template status and provider dashboard
Maps/geocoding failing	Switch provider in Admin → Settings → Maps (OSM ⇄ Google)
Cron not running	Dispatch self-advances on tracking polls; run `/api/cron/tick` manually with the bearer secret
Database unavailable	Neon status page; failover/restore; keep phone desk running